

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

Document 02

NYDFS Cybersecurity Framework Mapping

23 NYCRR Part 500 — Controls Mapping & Compliance Implementation

[New York State Department of Financial Services | Part 500](#)

Document ID:	NYDFS-01
Framework Layer:	LAYER 1: REGULATORY COMPLIANCE
Version:	1.0
Effective Date:	June 1, 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

1. Purpose

This document maps TSEC Risk & Cyber Advisory LLC's cybersecurity framework to the requirements of 23 NYCRR Part 500 (NYDFS Cybersecurity Regulation). It serves as the implementation guide for covered entities and financial institutions subject to NYDFS oversight, providing a structured approach to achieving and maintaining compliance.

2. NYDFS Part 500 Applicability

23 NYCRR Part 500 applies to covered entities including:

- Banks, trust companies, and licensed lenders operating under NY Banking Law
- Insurance companies regulated by NYDFS
- Money transmitters and virtual currency businesses (BitLicense)
- Mortgage bankers and servicers
- Premium finance agencies and other DFS-regulated entities

3. Part 500 Requirements Mapping

The following table maps each NYDFS Part 500 section to implementation requirements and TSEC controls:

Section	Requirement	Implementation Guidance	Status
500.02	Cybersecurity Program	Establish and maintain a cybersecurity program protecting information systems and NPI	Implement
500.03	Cybersecurity Policy	Board-approved written cybersecurity policy covering 14 specified areas	Documented
500.04	CISO	Designate a qualified CISO (internal or virtual/outsourced)	Assigned
500.05	Penetration Testing	Annual pen test; bi-annual vulnerability assessments	Scheduled
500.06	Audit Trail	Maintain audit trails for 3 years; financial records 5 years	Configured
500.07	Access Privileges	Implement least privilege; annual access reviews	Implemented
500.08	Application Security	Secure SDLC; periodic application security reviews	In Progress
500.09	Risk Assessment	Annual documented risk assessment; methodology documented	Completed

Section	Requirement	Implementation Guidance	Status
500.10	Cybersecurity Personnel	Qualified cybersecurity staff; annual training	Implemented
500.11	Third-Party Service Providers	TPRM program; written security requirements in all contracts	In Progress
500.12	Multi-Factor Authentication	MFA for remote access, privileged accounts, and critical systems	Implemented
500.13	Data Retention Limits	Dispose of NPI no longer needed; documented retention schedule	Documented
500.14	Training & Monitoring	Annual cybersecurity awareness training; user activity monitoring	Implemented
500.15	Encryption	Encrypt NPI in transit and at rest; compensating controls if infeasible	Implemented
500.16	Incident Response Plan	Written IRP; tested annually; roles and escalation defined	Documented
500.17	Notices to DFS	72-hour notification for cybersecurity events; annual certification	Compliant

4. Annual Certification Requirements

4.1 Annual Certification (Section 500.17)

Covered entities must submit an annual certification of compliance to the DFS Cybersecurity portal by April 15 each year. The certification must attest that:

- The covered entity is in compliance with 23 NYCRR Part 500
- A cybersecurity program is in place and operating effectively
- All required policies and procedures are documented and approved
- The CISO has reviewed and reported on the cybersecurity program to the board

4.2 Exemptions

Limited exemptions exist under Section 500.19 for entities with: fewer than 10 employees, less than \$5M gross annual revenue, or less than \$10M year-end total assets. Exemptions must be filed annually.

5. TSEC Implementation Support

Service	Description
NYDFS Gap Assessment	Full assessment against all 23 Part 500 requirements with findings report
Policy Development	NYDFS-compliant cybersecurity policy suite and supporting procedures
CISO-as-a-Service	Fractional CISO fulfilling Part 500.04 designation requirements
Annual Certification Support	Preparation and filing of annual DFS certification
Incident Response	IRP development, tabletop exercises, and DFS notification support
Ongoing Monitoring	Continuous compliance monitoring and quarterly status reporting

6. Contact & Engagement

Organization:	TSEC Risk & Cyber Advisory LLC
Email:	Info@tsecgrc.com
Website:	www.tsecgrc.com
Classification:	CONFIDENTIAL — For Client Use Only